

Operational Technology · Penetration Test & Risk Assessment

OT / ICS Security Assessment Report

Cascade Falls Regional Water Utility

Operational Technology Environment — ICS network 172.30.0.0/24 (Purdue Levels 1–2)

ENGAGEMENT ID	OTLAB-2026
ASSESSMENT WINDOW	17–20 September 2026
REPORT DATE	21 September 2026
VERSION	1.0 (Final)
CLASSIFICATION	CONFIDENTIAL — Restricted Distribution
ASSESSOR	R. Ramirez — OT/ICS Security Assessment
FRAMEWORKS	PTES · NIST SP 800-115 · MITRE ATT&CK for ICS · ISA/IEC 62443 · NIST CSF 2.0

● Overall risk rating: **CRITICAL** · Prepared for Cascade Falls Regional Water Utility (synthetic / fictional)

Assessment produced with **Ω Ohm AI** — local-first OT/ICS assessment engine

Document control

Version	Date	Author	Notes
0.1	2026-09-17	R. Ramirez	Draft — scope & asset inventory
0.9	2026-09-20	R. Ramirez	Findings & attack validation complete
1.0	2026-09-21	R. Ramirez	Final — executive summary, roadmap, QA

Distribution (synthetic): CISO; OT Engineering Manager; IT/OT Network Lead; GRC. **Handling:** Contains exploitation detail for control-system devices. Store encrypted; share on a need-to-know basis; do not forward outside the distribution list.

1. Executive summary

Cascade Falls engaged an independent OT security assessment of its water-treatment control network. The objective was to determine whether an adversary who reaches the OT network — through a compromised corporate workstation, a rogue device, or an exposed remote-access path — could observe or manipulate the physical treatment process.

They can, trivially, and without any credentials. Every programmable logic controller (PLC) in the treatment process accepts unauthenticated commands over Modbus/TCP. During testing we did not merely detect this exposure; we safely demonstrated it, altering a live process register and toggling an actuator command bit on all four field controllers, then restoring the original values. In a production environment the same actions would let an attacker open or close valves, start or stop pumps, and falsify setpoints across raw-water intake, filtration, chemical dosing, and well control.

The root causes are architectural, not incidental. The controllers implement no authentication because the Modbus protocol offers none, and the network does nothing to compensate: there is no segmentation between control devices, the operator interfaces are served in cleartext, and the corporate-to-OT firewall boundary permits nearly all traffic. The environment relies on obscurity and physical isolation, both of which fail the moment any foothold exists on the OT LAN.

Overall risk rating: CRITICAL.

Key findings at a glance

ID	Finding	Severity
OT-001	Unauthenticated Modbus read/write on all four process PLCs (control manipulation demonstrated)	Critical
OT-002	Corporate-to-OT firewall boundary is effectively open (overly permissive <code>permit ip</code>)	High
OT-003	No east-west segmentation within the OT network (flat Level 1)	High
OT-004	Operator HMI and process historian served over cleartext HTTP	Medium
OT-005	Broad unauthenticated ICS protocol exposure (S7comm, SNMP, BACnet, EtherNet/IP, FTP)	Medium
OT-006	EtherNet/IP CIP device-identity disclosure	Low

What we recommend first

- Put a controls-aware boundary in front of the PLCs.** Deny Modbus/502 by default and allow it only from named engineering hosts, enforced by an OT firewall or data diode, not a flat corporate ACL.
- Segment Level 1.** Place controllers in zones/conduits so a single foothold cannot reach every device.
- Wrap the protocols that cannot authenticate.** Where controllers must remain reachable, front them with an authenticating, logging proxy or terminate access through a monitored jump host.
- Deploy OT-aware monitoring.** Unauthenticated writes and coil changes are high-signal events; today nothing would detect them.

A phased remediation roadmap appears in Section 9.

2. Assessment overview

2.1 Scope

Item	Detail
In-scope network	172.30.0.0/24 (OT / ICS)
In-scope hosts	7 (five Level 1 field devices, two Level 2 control systems)
Explicitly out of scope	Corporate network 10.10.0.0/16 , the assessor tooling host, and all external addresses
Assessment type	Grey-box: asset inventory and boundary configuration provided; no device credentials supplied
Test perspective	Adversary with network access to the OT LAN (post-foothold)

2.2 Objectives

- Enumerate reachable control-system services and their authentication posture.
- Determine whether the physical process can be observed or manipulated without credentials.
- Evaluate the IT/OT boundary and internal segmentation.
- Map exposures to recognized control-system risk frameworks and provide prioritized remediation.

2.3 Rules of engagement

Testing was authorized against the synthetic environment only. A hard, fail-closed scope gate rejected every out-of-scope address before any tool touched it, and each authorized action was written to a tamper-evident, hash-chained audit log prior to execution. All process manipulations were non-destructive and reversed immediately (original register and coil values restored). No denial-of-service, firmware, or safety-system testing was performed.

2.4 Timeline

Date	Activity
2026-09-17	Environment stand-up, asset inventory, scope authorization
2026-09-20	Governed assessment, exposure validation, controlled exploitation
2026-09-21	Reporting and QA

2.5 Limitations

The environment is synthetic and models a subset of a real plant (no safety instrumented system, no engineering workstation, no real physical process). Findings reflect the modeled devices and protocols. CVSS scores are provided for prioritization and blend the CVSS v3.1 base metric with OT-specific likelihood and consequence, consistent with common ICS-assessment practice.

3. Methodology & standards

The engagement followed a structured, controls-safe methodology aligned to:

- **PTES** (Penetration Testing Execution Standard) — phased engagement structure.
- **NIST SP 800-115** — technical assessment (discovery, enumeration, validation).
- **MITRE ATT&CK for ICS** — adversary technique mapping (Section 8).
- **ISA/IEC 62443** — zones/conduits and Foundational Requirements (FR1–FR5) for remediation framing.
- **NIST CSF 2.0 → SP 800-53 Rev 5** — control crosswalk (Section 10).
- **Purdue Enterprise Reference Architecture** — level model for the asset inventory.

Phases: (1) reconnaissance and asset validation; (2) service enumeration and authentication analysis; (3) controlled exploitation to confirm impact; (4) boundary and segmentation review; (5) risk analysis and reporting. Where automated tooling could not reach a device safely, enumeration was delegated to an isolated in-network assessor host, and all activity was scope-gated and audited.

4. Environment & asset inventory

The OT network follows a Purdue model with field controllers at Level 1 and supervisory systems at Level 2.

Device	IP	Type	Vendor (modeled)	Purdue zone	Criticality	Reachable services
PLC-RAW-01	172.30.0.11	PLC	Allen-Bradley	Level 1 — Raw Water	High	Modbus/502
PLC-FILT-02	172.30.0.12	PLC	Siemens	Level 1 — Filtration	High	Modbus/502
PLC-CHEM-03	172.30.0.13	PLC	Allen-Bradley	Level 1 — Chemical	High	Modbus/502
RTU-WELL-04	172.30.0.21	RTU	SEL	Level 1 — Wells	High	Modbus/502
PLC-SIM-05	172.30.0.30	PLC	Siemens	Level 1 — Process	High	Modbus/5020, S7comm/10201, EtherNet-IP/44818, FTP/2121, SNMP, BACnet
HMI-OPS-01	172.30.0.31	HMI	Wonderware	Level 2 — Control	Medium	HTTP/80
HIST-01	172.30.0.40	Historian	OSIsoft PI	Level 2 — Control	High	HTTP/80

Architecture observation. All Level 1 devices share a single flat broadcast domain with no internal zoning. The two Level 2 systems sit on the same network. There is no intermediate DMZ between Level 2 and the corporate network beyond a single stateless ACL (Section 7 / OT-002).

5. Findings summary

ID	Finding	Severity	CVSS v3.1	Affected assets	Status
OT-001	Unauthenticated Modbus read/write; control manipulation demonstrated	Critical	9.4	.11 .12 .13 .21	Open
OT-002	Overly permissive IT/OT firewall boundary	High	8.6	Boundary ACL	Open
OT-003	No east-west segmentation within OT (flat Level 1)	High	7.6	All OT	Open
OT-004	Cleartext HTTP on HMI and historian	Medium	5.9	.31 .40	Open
OT-005	Broad unauthenticated ICS protocol exposure	Medium	6.5	.30	Open
OT-006	EtherNet/IP CIP identity disclosure	Low	3.7	.30	Open

Severity distribution: 1 Critical · 2 High · 2 Medium · 1 Low. *(The automated engine counts findings per exposed endpoint and reports 4 Critical / 5 Medium / 1 Low; this report consolidates the four identical PLC exposures into one systemic finding, OT-001, which is how the risk should be governed and remediated.)*

Risk rating methodology

Severity blends CVSS v3.1 base score with an OT likelihood-vs-consequence matrix. Consequence weighting is raised for findings that affect process integrity or availability, because in a control environment the loss condition is physical (safety, environmental, service continuity), not data confidentiality.

	Negligible	Moderate	Severe (process/physical)
High likelihood	Medium	High	Critical
Medium likelihood	Low	Medium	High
Low likelihood	Low	Low	Medium

6. Detailed findings

OT-001 — Unauthenticated Modbus read/write on all process PLCs

Severity: **CRITICAL** · CVSS v3.1 **9.4** AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:H · CWE-306 (Missing Authentication for Critical Function), CWE-284 (Improper Access Control) **Affected:** PLC-RAW-01 (.11), PLC-FILT-02 (.12), PLC-CHEM-03 (.13), RTU-WELL-04 (.21) **MITRE ATT&CK for ICS:** T0886 Remote Services · T0846 Remote System Discovery · T0855 Unauthorized Command Message · T0836 Modify Parameter · T0831 Manipulation of Control **ISA/IEC 62443:** violates FR1 (Identification & Authentication Control) and FR2 (Use Control)

Description. All four field controllers expose Modbus/TCP on port 502 with no authentication and no transport security. Any host able to reach the device can read holding/input registers and coils and, critically, **write** to them. Modbus has no native concept of identity, so the device cannot distinguish an engineering workstation from an attacker.

Evidence (controlled exploitation). For each controller we read a holding register, wrote a sentinel value, read it back to confirm the write took effect, then flipped a coil (an actuator command bit such as pump run/valve open) and restored both to their original values:

Device	Unit ID	Register 10 before → after	Unauth. write confirmed	Coil flip confirmed
PLC-RAW-01	1	172 → 1337	Yes	Yes
PLC-FILT-02	2	145 → 1337	Yes	Yes
PLC-CHEM-03	3	128 → 1337	Yes	Yes
RTU-WELL-04	4	180 → 1337	Yes	Yes



Figure 1 — Attacker console: the rig confirms unauthenticated Modbus writes on all four field controllers. Holding register 10 was changed 172 → 1337 and an actuator coil was toggled and restored.

Raw evidence: `attack/out/attack_modbus.json`, `assess/out/modbus.json`.

Business impact. An attacker can manipulate the physical treatment process: alter chemical dosing setpoints, start/stop pumps, open/close valves, and falsify the values operators rely on. Consequences range from service disruption to water-quality and public-safety events. This maps to the ICS impact conditions **Loss of Control (T0827)**, **Loss of Availability (T0826)**, and potentially **Loss of Safety (T0880)**.

Likelihood: High. No credentials, no user interaction, and off-the-shelf tooling. The only barrier is network reachability, which OT-002 and OT-003 largely remove.

Remediation.

- *Tactical:* Restrict Modbus/502 to an explicit allowlist of engineering hosts at a controls-aware firewall; deny by default. Enable device-side write protection / run-mode key switches where the platform supports them.
- *Strategic:* Introduce an authenticating, logging Modbus proxy or migrate reachable interfaces to authenticated protocols. Adopt ISA/IEC 62443 zones and conduits so control traffic is brokered, not flat. Baseline expected register/coil writes and alert on deviations.

OT-002 — Corporate-to-OT firewall boundary is effectively open

Severity: HIGH · CVSS v3.1 8.6 AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:L · CWE-1120 / CWE-284 (overly permissive access control) **Affected:** IT/OT boundary ACL (IT_TO_OT) **MITRE ATT&CK for ICS:** T0886 Remote Services · T0819 Exploit Public-Facing Application (as a conduit into OT) **ISA/IEC 62443:** violates FR5 (Restricted Data Flow)

Description. The boundary ACL denies telnet (23) and Modbus (502) inbound to OT, then contains a broad `permit ip 10.10.10.0 0.0.0.255 172.30.0.0 0.0.0.255`. Because that rule permits **all IP** from the corporate subnet to the entire OT range, every OT service other than the two explicitly denied ports — S7comm, HTTP, SNMP, BACnet, EtherNet/IP, FTP — is reachable from any corporate host. The boundary is a flat allow with two exceptions, not a controlled conduit.

Evidence. Rule analysis of the provided boundary configuration (`engagement/raw_inputs/otlab_boundary.cfg`); full breakdown in Appendix C.

Business impact. A single compromised corporate workstation becomes a launch point into OT for everything except the two blocked ports. The Modbus deny is also brittle: it depends on rule order and does not stop an attacker who reaches OT by any other path (rogue device, remote access, wireless, the exposed surface exercised in Section 8).

Likelihood: High. Corporate-workstation compromise is the most common real-world initial-access vector, and this boundary does little to contain it.

Remediation. Replace the flat `permit ip` with least-privilege, service-specific rules to named hosts. Deny by default. Insert an OT DMZ so no corporate host talks directly to Level 1/2. Prefer a controls-aware firewall (or unidirectional gateway for historian egress) over a stateless router ACL.

OT-003 — No east-west segmentation within the OT network

Severity: HIGH · CVSS v3.1 7.6 AV:A/AC:L/PR:N/UI:N/S:C/C:L/I:H/A:L · CWE-923 (Improper Restriction of Communication Channel) **Affected:** entire OT network (all Level 1 and Level 2 hosts) **MITRE ATT&CK for ICS:** T0846 Remote System Discovery · T0840 Network Connection Enumeration · lateral reach to T0855 **ISA/IEC 62443:** violates FR5 (Restricted Data Flow) — absence of zones and conduits

Description. All controllers and supervisory systems share one flat subnet with no internal zoning. Any device on the OT LAN can reach every other device on every port. There is no conduit brokering traffic between the raw-water, filtration, chemical, and well control functions.

Evidence. In-network enumeration from the assessor host reached all seven devices without restriction; Modbus was reachable device-to-device across the flat segment.

Business impact. This is the multiplier on OT-001. One foothold anywhere — a maintenance laptop, a vendor device, a compromised HMI — yields control of every process. It also removes any blast-radius containment during an incident.

Likelihood: Medium–High. Requires a foothold on the OT LAN, which OT-002 and the exposed surface make attainable.

Remediation. Define ISA/IEC 62443 zones per process function with conduits between them. Enforce with VLANs plus an OT firewall, not switch ACLs alone. Restrict engineering access through a hardened, monitored jump host.

OT-004 — Operator HMI and historian served over cleartext HTTP

Severity: MEDIUM · CVSS v3.1 **5.9** `AV:A/AC:H/PR:N/UI:R/S:U/C:H/I:L/A:N` · CWE-319 (Cleartext Transmission of Sensitive Information) **Affected:** HMI-OPS-01 (.31), HIST-01 (.40) **MITRE ATT&CK for ICS:** T0842 Network Sniffing · T0801 Monitor Process State **ISA/IEC 62443:** violates FR4 (Data Confidentiality)

Description. The operator interface and the process historian are served over unauthenticated cleartext HTTP. We retrieved both pages without credentials; the historian self-identifies as an OSIsoft PI Data Archive 2018 SP3 with its interfaces enumerated. An on-path attacker can read process state and any session material, and the pages themselves disclose architecture useful for targeting.

Evidence. Retrieved pages: `attack/out/web_HMI-OPS-01.html` , `attack/out/web_HIST-01.html` .

PI Data Archive

HIST-01 · 172.30.0.40

Server: OSIsoft PI Data Archive 2018 SP3 (synthetic)

Role: process historian — Level-2 control network

Interfaces: PI Web API (HTTP), OPC-UA collector, SNMP agent

Points: 4,812

Streams: raw-water, filtration, chemical dosing, well field

Note: This is a fictional target in an isolated OT assessment lab. No real data.

Endpoints: `/piwebapi` · `/health` — unauthenticated (by design, for assessment)

Figure 2 — Process historian retrieved without credentials over cleartext HTTP. The page self-identifies as OSIsoft PI Data Archive 2018 SP3 and enumerates its interfaces (PI Web API, OPC-UA collector, SNMP agent).

Business impact. Process visibility and system fingerprinting for an attacker; exposure of any credentials or tokens transmitted in the clear; a foothold for view manipulation.

Remediation. Enforce TLS with modern ciphers and authentication on all OT web interfaces. Restrict access to operator VLANs. Remove verbose product/version banners.

OT-005 — Broad unauthenticated ICS protocol exposure

Severity: MEDIUM · CVSS v3.1 6.5 AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N · CWE-306 **Affected:** PLC-SIM-05 (.30) **MITRE ATT&CK for ICS:** T0888 Remote System Information Discovery · T0846 Remote System Discovery **ISA/IEC 62443:** violates FR1 / FR2

Description. The multi-protocol process device exposes S7comm (10201), Modbus (5020), EtherNet/IP (44818), FTP (2121), SNMP, and BACnet, all without authentication. Each protocol permits identity enumeration and, for several, read of device state. The breadth of exposed, legacy, unauthenticated services on a single node substantially enlarges the attack surface.

Evidence. NSE discovery (`attack/out/attack_recon_nse.txt`) and assessment scan (`assess/out/otlab_tcp.xml` , `otlab_udp.xml` , `otlab_s7.xml`) confirm the open, unauthenticated services.

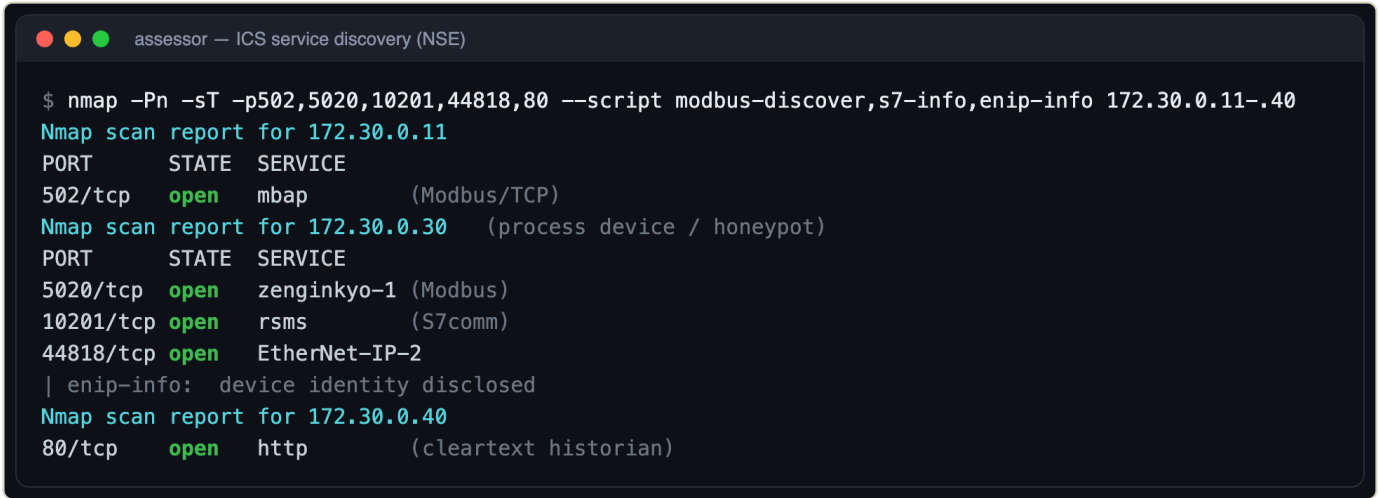


Figure 3 — ICS service discovery: the process device (172.30.0.30) exposes Modbus, S7comm, and EtherNet/IP simultaneously, with CIP identity disclosed via `enip-info`.

Technodrome

Status:

Current time:

20:53:11

System uptime:

160 timeticks (deciseconds)

Figure 4 — The process device serves a cleartext Siemens SIMATIC S7-200 status page (device clock and uptime) with no authentication.

Business impact. Reconnaissance and device fingerprinting; likely default SNMP community access; legacy FTP as a weak-credential foothold. Any of these can seed deeper compromise.

Remediation. Disable unused protocols and services. Where a protocol is required, restrict it by allowlist and place it behind an authenticating proxy. Replace FTP with SFTP; change default SNMP communities or move to SNMPv3.

OT-006 — EtherNet/IP CIP identity disclosure

Severity: **LOW** · CVSS v3.1 **3.7** **AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N** · CWE-200 (Information Exposure)

Affected: PLC-SIM-05 (.30) **MITRE ATT&CK for ICS:** T0888 Remote System Information Discovery **ISA/IEC 62443:** relates to FR4

Description. The EtherNet/IP (CIP) service on 44818 responds to identity queries, disclosing device attributes useful for fingerprinting and exploit selection.

Remediation. Restrict 44818 to engineering hosts; suppress or minimize CIP identity responses where the platform allows.

7. IT/OT boundary firewall analysis

The provided boundary enforces the corporate (10.10.0.0/16) ↔ OT (172.30.0.0/24) edge with two IOS-style extended ACLs.

IT_TO_OT (inbound to OT), evaluated top-down:

#	Rule	Effect
1	permit tcp 10.10.10.0/24 → host .40 eq 5450	Historian access (specific) — reasonable
2	permit tcp 10.10.10.0/24 → host .40 eq 443	Historian HTTPS (specific) — reasonable
3	permit udp 10.10.5.0/24 → host .30 eq 161	SNMP to process device — over-broad target
4	deny tcp any → OT eq 23 log	Blocks telnet — good
5	deny tcp any → OT eq 502 log	Blocks Modbus — good, but order-dependent
6	permit ip 10.10.10.0/24 → 172.30.0.0/24	Permits ALL other IP corp→OT — the core weakness (OT-002)
7	deny ip any any log	Implicit-deny backstop

Rule 6 undermines the intent of rules 4–5: everything except telnet and Modbus is allowed from corporate to all of OT. **OT_TO_IT** is tighter (historian HTTPS egress only, then deny-all). **Net effect:** the boundary blocks two ports and permits the rest — a deny-two posture where a default-deny posture is required.

8. Attack narrative (kill chain)

The following reproduces an adversary who has reached the OT-reachable surface, mapped to MITRE ATT&CK for ICS tactics. All actions were authorized, non-destructive, and reversed.

1. **Initial Access / Discovery (T0886, T0846, T0840).** From the assessment position we enumerated the OT range and identified four PLCs on Modbus/502, a multi-protocol process node, and two Level 2 web systems. The flat network (OT-003) meant discovery was unimpeded.
2. **Collection / Process visibility (T0801, T0842).** Cleartext HMI and historian pages were retrieved without credentials, revealing process state and platform detail (OSIsoft PI 2018 SP3).
3. **Impair Process Control (T0855, T0836, T0831).** On each of the four PLCs we issued unauthenticated writes — modifying a holding register and toggling an actuator coil — and confirmed the change took effect by reading it back. Original values were then restored.
4. **Impact (potential) (T0826, T0827, T0880).** In production the same primitives yield loss of control and availability of the treatment process, with a credible path to a safety or water-quality event.

The engagement stopped at demonstrated control. No persistence, destruction, or safety-system interaction was attempted.

9. Strategic recommendations & remediation roadmap

Prioritized by risk reduction per unit of effort.

Phase 1 — Immediate (0–30 days): stop unauthenticated control.

- Deny Modbus/502 by default at a controls-aware boundary; allow only named engineering hosts (OT-001).
- Replace the flat `permit ip` corporate→OT rule with least-privilege service rules; deny by default (OT-002).
- Enable device write-protection / run-mode key switches where available.

Phase 2 — Near term (30–90 days): contain and observe.

- Segment Level 1 into ISA/IEC 62443 zones with conduits; introduce an OT DMZ between Level 2 and corporate (OT-003).
- Enforce TLS and authentication on HMI and historian; restrict to operator VLANs (OT-004).
- Deploy OT-aware monitoring (passive ICS IDS); alert on unauthenticated writes, coil changes, and new Modbus masters.

Phase 3 — Structural (90–180 days): reduce and govern.

- Disable unused ICS protocols; front required ones with authenticating proxies; retire FTP/cleartext SNMP (OT-005, OT-006).
- Establish an engineering jump host as the sole path to Level 1.
- Stand up an OT asset inventory and vulnerability-management program; formalize an ICS incident-response plan.

Residual risk statement. Until Phase 1 completes, the environment should be treated as offering full process control to any party with OT network access. Compensating controls (physical access restriction, continuous monitoring of the OT LAN) should be assumed insufficient on their own.

10. NIST CSF 2.0 → SP 800-53 Rev 5 crosswalk

Generated deterministically from the assessment evidence (offline, no LLM).

CSF 2.0 subcategory	SP 800-53 controls	Relevant findings
PR.IR-01 (protect network integrity)	AC-4 (information flow), SC-7 (boundary protection)	OT-002, OT-003
PR.AA-01 (identity & access)	AC-2 (account management), IA-2 (identification & authentication)	OT-001, OT-005
ID.AM-03 (data flow mapping)	CA-3 (system interconnections)	OT-002, OT-003
DE.CM-01 (continuous monitoring)	SI-4 (system monitoring)	all — no OT monitoring present

11. Appendices

Appendix A — Tooling & environment

Governed assessment via a scope-gated, hash-chain-audited driver over an isolated in-network assessor (nmap with ICS NSE: `modbus-discover`, `s7-info`, `enip-info`; pymodbus 3.6.x for deep Modbus enumeration). Exploitation validation via a Modbus/HTTP attack client against the exposed surface. Reporting via a deterministic NIST catalog engine (CSF 2.0 / SP 800-53), fully offline. Note: the host nmap build was non-functional (Homebrew lua ABI break); NSE was executed from the assessor container.

Appendix B — Asset inventory

See Section 4. Source: `engagement/raw_inputs/otlab_assets.csv`.

Appendix C — Firewall rule analysis

See Section 7. Source: `engagement/raw_inputs/otlab_boundary.cfg`.

Appendix D — Evidence index

Evidence	Path
Modbus exploitation (pre/post writes, coil flips)	<code>attack/out/attack_modbus.json</code>
Modbus enumeration (assessment)	<code>assess/out/modbus.json</code>
Retrieved HMI / historian / process web pages	<code>attack/out/web_*.html</code>
NSE discovery	<code>attack/out/attack_recon_nse.txt</code>
nmap TCP / UDP / S7 scans	<code>assess/out/otlab_tcp.xml</code> , <code>otlab_udp.xml</code> , <code>otlab_s7.xml</code>
Governed audit chain (11 records, verified)	<code>assess/out/audit_chain.json</code>
Machine-readable assessment artifact	<code>engagement/assessment_artifact.json</code>

Appendix E — Severity definitions

Critical — trivially exploitable and directly affects physical process integrity or availability. **High** — significant exposure or a strong enabler of critical impact. **Medium** — meaningful weakness requiring conditions or chaining. **Low** — limited impact / information disclosure.

Appendix F — Glossary

PLC (Programmable Logic Controller) · RTU (Remote Terminal Unit) · HMI (Human-Machine Interface) · Modbus/TCP (unauthenticated industrial protocol, port 502) · S7comm (Siemens control protocol) · CIP / EtherNet/IP (Common Industrial Protocol) · Purdue Model (ICS network reference levels) · Zone/Conduit (ISA/IEC 62443 segmentation constructs).

Prepared for Cascade Falls Regional Water Utility (SYNTHETIC). This report contains control-system exploitation detail and is classified CONFIDENTIAL — Restricted Distribution. End of report.